

AUDSPECT

Breach & Attack Simulation Platform

Adversary Simulation Assessment Report

RBI Ransomware Resilience Sweep

RISK: HIGH RISK

Prepared for	BANK-WS-01
Endpoint	Windows 11 Pro 23H2
Environment	Production
Assessment date	20 June 2026, 11:07 UTC
Report generated	20 June 2026, 11:07 UTC
Run reference	run-abcd

1. Executive Summary

PRODUCTION ENVIRONMENT

This assessment executed live adversary techniques against a production endpoint. Endpoint changes were reverted where the snapshot system captured them — see section 7 (Changes & Cleanup Verification).

This report presents the results of an automated breach & attack simulation executed against BANK-WS-01 (Windows 11 Pro 23H2) on 20 June 2026. The assessment ran 12 MITRE ATT&CK-aligned techniques to measure how effectively the endpoint's security controls prevent real adversary behaviour.

Of the techniques executed, 5 were prevented or blocked by a security control and 7 executed successfully without being stopped. This yields a prevention effectiveness of 41% and an overall risk classification of High Risk (risk score 72/100). Consecutive failures across adjacent kill-chain phases amplified exposure by 1.8×, indicating an attacker could chain multiple steps with limited resistance. A further 2 technique(s) could not be evaluated (execution errors — malformed test content, timeouts, missing prerequisites or scheduler contention) and 0 were skipped; both are excluded from the prevention and exposure scores so they neither inflate nor deflate the result.

1 critical or high-severity technique(s) were not prevented and require prioritised remediation (see Key Findings). Testing exercised 2 of the 14 MITRE ATT&CK Enterprise tactics across 12 technique(s) — this is the breadth of THIS run, not a measure of overall MITRE ATT&CK coverage. Broadening scenario coverage in future runs will increase assurance. Prioritised recommendations are provided in section 8.

Overall posture: High Risk (risk score 72 / 100, Baseline)

12 techniques · 5 prevented · 7 succeeded · 2 errored · 0 skipped · 1 critical/high finding(s)

Trend vs Previous Assessment

Prevention effectiveness is 41% this run versus 28% in the previous assessment.

IMPROVED +13 PTS

Prevention over the last 3 assessments (oldest to newest):

18 Jun 2026		20%
19 Jun 2026		28%
20 Jun 2026		41%

Prevention & Detection

7 technique(s) executed without being prevented. A FAIL means a prevention control did not stop execution — not that the attacker's end objective was independently verified. Of those that executed:

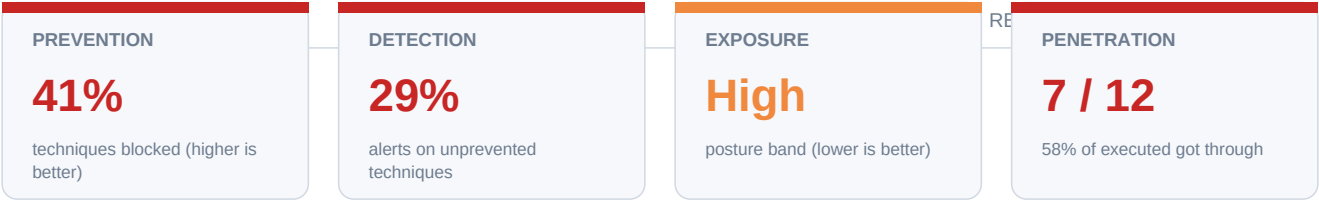
2	Detected	an alert fired (Microsoft Defender) — a SOC would see this
3	Logged only	telemetry exists but no alert was raised
2	Undetected	no telemetry observed — executed unseen (worst case)

Business-Objective Risk

What an attacker could achieve against this endpoint, by objective — derived from the tested techniques in each area (execution errors excluded).

Credential Theft	HIGH RISK	3 of 3 technique(s) unprevented
Persistence	LOW RISK	0 of 2 technique(s) unprevented
Code Execution	MEDIUM RISK	1 of 3 technique(s) unprevented

2. Assessment Scorecard



Tactic breadth: 2 / 14 · Defense rate: 0% · Mean time-to-detect: 3m 12s · Result confidence: Medium (12 valid of 14 attempted, 2 errored)

Attack Surface Age: Exposed weakness present for 147 days

Known weakness: T1003 (OS Credential Dumping) · Status: CRITICAL-SLA

Endpoint Stability Check — Health Impact: Negligible

Before Running: CPU: 2.1% · RAM: 5.4 GB · Disk: 62.5% | After Running: CPU: 2.3% · RAM: 5.4 GB · Disk: 62.5%

Detection Source Ranking			
PRODUCT	DETECTIONS	MIN TIME-TO-DETECT	AVG TIME-TO-DETECT
1. Trellix	18	4s	8s
2. Defender	14	2s	4s

Assessment Insights

MOST PROTECTED

Execution (66%)

LEAST PROTECTED

Credential Access (0%)

Control Maturity by Category

Maturity (0–10) per control family, from this run's prevention rate — a management view of which controls held and which need investment. Derived from tested techniques only.



3. Methodology & Scope

Framework	MITRE ATT&CK (Enterprise)
Engines	Atomic Red Team
Target endpoint	BANK-WS-01 — Windows 11 Pro 23H2
Asset class	Workstation (inferred from OS)
Environment	Production
Business criticality	High — production endpoint
Security context	Microsoft Defender (real-time protection ON), EDR: CrowdStrike Falcon, EDR: Sysmon
Techniques executed	12
Tactics exercised	2 of 14 ATT&CK tactics
Window	20 Jun 2026 11:07 UTC

Security context lists the AV/EDR products detected on the endpoint (presence only). Detection by third-party EDR is not locally observable and is therefore never asserted in this report.

Each technique is scored as PASS when a security control prevented or blocked it, FAIL when it executed without being stopped, ERROR when the test itself could not execute correctly (malformed content, timeout, missing

prerequisite, scheduler contention), or SKIPPED when it was not run. Only PASS and FAIL count toward the score — a FAIL is a finding — the simulated adversary behaviour succeeded against this endpoint — while ERROR and SKIPPED are excluded because they reflect a test-execution problem, not the endpoint's defences.

4. ATT&CK Tactic Breakdown

Execution		66%	2 pass · 1 fail
Credential Access		0%	0 pass · 3 fail

5. Key Findings

Top Risk Drivers

Techniques whose failures account for the most lost prevention points (the points each accounts for, not a promised gain from any single fix).

1. T1003 OS Credential Dumping (Credential Access)

30.0 PTS · 3F · CRITICAL
2. T1059.001 PowerShell (Execution)

7.5 PTS · 1F · HIGH

Realized Attack Path

The unprevented techniques from this run, ordered by kill-chain phase. An attacker chaining these consecutive phases met limited resistance — this is the path the endpoint's gaps actually permit, derived from observed FAILs (no inferred causal links).

Execution

T1059.001 — PowerShell

Persistence

T1547 — Boot Autostart

Credential Access

T1003 — OS Credential Dumping

CRITICAL

F-01 T1003 — OS Credential Dumping

Credential Access

What happened LSASS memory was read without being blocked.

Remediation Enable Credential Guard and LSA protection.

Threat Intelligence (MITRE ATT&CK)

Known threat actors	APT28, APT32, APT34, APT39, Axiom, Dragonfly, Ember Bear, Frankenstein, Leviathan, Poseidon Group, +3 more
Associated malware/tools	Azorult, Carbanak, HOMEFRY, KONNI, MgBot, OnionDuke, PinchDuke, Revenge RAT, Trojan.Karagany
Mitigations (ATT&CK)	Active Directory Configuration; Behavior Prevention on Endpoint; Credential Access Protection; Credential Dumping Mitigation; Encrypt Sensitive Information; Operating System Configuration; +2 more
Platforms	Windows, Linux, macOS
Detection data sources	Active Directory: Active Directory Object Access; Command: Command Execution; File: File Access; File: File Creation; Network Traffic: Network Traffic Content; Network Traffic: Network Traffic Flow; Process: OS API Execution; Process: Process Access; +2 more
Windows telemetry (Sysmon/WEL)	Sysmon 1, Windows Security 4688, PowerShell 4104, Windows Security 4663, Sysmon 11, Sysmon 3, Windows Security 5156, Sysmon 10, Sysmon 12-14, Windows Security 4657
ATT&CK version	v2.2 · created 2017-05-31 · updated 2024-10-15
ATT&CK reference	https://attack.mitre.org/techniques/T1003

Adversary Knowledge Graph

Threat actors and malware known (per MITRE ATT&CK) to use the techniques that went unprevented in this run, ranked by how many of those techniques they cover — the real-world adversaries these gaps expose you to.

Threat actors that use these techniques

APT28	1 technique(s): T1003
APT32	1 technique(s): T1003
APT34	1 technique(s): T1003
APT39	1 technique(s): T1003
Axiom	1 technique(s): T1003
Dragonfly	1 technique(s): T1003
Ember Bear	1 technique(s): T1003

Malware / tools that implement these techniques

Azorult	1 technique(s): T1003
Carbanak	1 technique(s): T1003
HOMEFRY	1 technique(s): T1003
KONNI	1 technique(s): T1003
MgBot	1 technique(s): T1003
OnionDuke	1 technique(s): T1003
PinchDuke	1 technique(s): T1003
Revenge RAT	1 technique(s): T1003

Threat-intelligence context derived from MITRE ATT&CK®. © The MITRE Corporation. ATT&CK® is a registered trademark of The MITRE Corporation.

6. Detailed Technique Results

Results are grouped by ATT&CK technique. Each technique shows how many of its tests executed, were blocked, or errored. ERROR tests (a BAS execution problem, not a security outcome) are summarised in the counts and excluded from scoring.

T1059.001 — PowerShell

Execution · High · Active Adversary Behavioral Test

1 test(s): 1 executed · 0 blocked · 0 errored · 0 skipped

Threat impact An attacker can run arbitrary code in memory, evading file-based AV.

Remediation Enable Constrained Language Mode and script block logging.

FAIL

Encoded PowerShell command executed successfully.

Detection: Microsoft Defender raised a detection (event 1116)

T1003 — OS Credential Dumping

Credential Access · Critical · Active Adversary Behavioral Test

1 test(s): 0 executed · 1 blocked · 0 errored · 0 skipped

PASS

Access to LSASS was denied by the security control.

Blocked by: Microsoft Defender (ASR rule)

T1547 — Boot Autostart

Persistence · Medium · Active Adversary Behavioral Test

1 test(s): 0 executed · 0 blocked · 0 errored · 1 skipped

T1112 — Modify Registry

Defense Evasion · High · Active Adversary Behavioral Test

1 test(s): 0 executed · 0 blocked · 1 errored · 0 skipped

7. Changes & Cleanup Verification

Warning: Cleanup failed

Out of the executed techniques, 2 failed to clean up successfully. Residual simulation artifacts (files or registry entries) may remain on the endpoint. SOC/security teams should review the logs below to perform manual remediation.

The agent reverted 2 endpoint change(s) made during the run. Cleanup status: WARNING — cleanup failed for one or more techniques. Some captured changes could not be rolled back automatically.

- Registry: HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\AtomicTest (deleted)
- File: C:\Windows\TEMP\nanodump.dmp (deleted)

Scope note: residual-artifact tracking covers changes captured by the pre-run snapshot (registry keys and files the engine instruments). Out-of-band changes a technique may make outside that scope are not tracked here — verify manually for high-impact techniques run in production.

8. Action Plan

Ordered by the prevention-score points each tactic's failures account for (severity-weighted, the same weighting as the headline score).

- 1 Credential Access — Credential Theft** 30.0 PTS · 3F
- Enable Credential Guard / LSASS protection and alert on LSASS access.

- 2 Execution — Code Execution** 7.5 PTS · 1F
- Constrain script engines (PowerShell CLM, WSH) and enforce application control.

Additional Guidance

- 1** Deploy application allow-listing to block unsigned binaries.
- 2** Enable tamper protection on the EDR agent.

9. Appendix — Metric Definitions

PASS	A security control prevented or blocked the simulated technique. More passes is better.
FAIL	A prevention control did not stop the technique from executing — a finding requiring attention. This means execution was permitted; it does NOT independently verify the attacker's end objective was achieved (e.g. that credentials were actually exfiltrated), which is technique-specific. Check the Detection line for whether the execution was also detected.
Detection	Whether the executed technique was seen by locally-observable telemetry: Detected (a Microsoft Defender alert fired), Logged only (Sysmon/Security telemetry exists but no alert), or Undetected (no telemetry). Third-party EDR detection is not locally observable and is never asserted.
Blocked by	The control credited with blocking a technique, when local evidence (a Microsoft Defender event or a recognisable block signature in the output) supports it. Where no control can be evidenced locally, the report states that an active control blocked it without naming a product — it never guesses.
Trend	Change in prevention effectiveness versus the previous scored assessment for this endpoint, with a short history. Appears once a second assessment has completed.
Threat Intelligence	Per-technique context from MITRE ATT&CK® (threat actors, malware/tools, mitigations) — authoritative, published by MITRE. CVE/KEV/OWASP/CWE shown as 'illustrative' are analyst-curated context, not an authoritative per-technique mapping, and should be read as examples, not an exhaustive list.
ERROR	The test could not execute correctly (malformed content, timeout, missing prerequisite, scheduler contention). A BAS execution problem, not a security outcome — excluded from scoring.
SKIPPED	The technique was deliberately not run (e.g. external payload not shipped) and was excluded from scoring.
Policy Configuration Check	A passive audit that inspects a security setting (registry key, policy, service state) without running an attack — it confirms whether a control is correctly configured.
Active Adversary Behavioral Test	An ART or Caldera test that actually executes the technique on the endpoint — it confirms whether deployed controls stop a live attack, not just whether they are configured.
Prevention	Severity-weighted percentage of techniques that were prevented. Higher is better.
Exposure	Tactic-weighted failure rate, amplified by consecutive kill-chain failures. Lower is better.
Tactic Breadth	Breadth of THIS run: how many of the 14 MITRE ATT&CK Enterprise tactics it exercised. Not a

measure of overall MITRE ATT&CK technique coverage — running more Atomics in a tactic does not increase ATT&CK coverage.

Defense Rate

Share of tested tactics in which every technique was blocked (zero failures).

Kill-chain amplifier

Multiplier (1.0–2.5×) reflecting consecutive unprevented kill-chain phases.

Risk classification

Overall posture band derived from the amplified exposure score.

	measure of overall MITRE ATT&CK technique coverage — running more Atomics in a tactic does not increase ATT&CK coverage.
Defense Rate	Share of tested tactics in which every technique was blocked (zero failures).
Kill-chain amplifier	Multiplier (1.0–2.5×) reflecting consecutive unprevented kill-chain phases.
Risk classification	Overall posture band derived from the amplified exposure score.